

## EXECUTIVE SUMMARY

# Finexa (example)

Digital infrastructure · Finexa SAS · SIREN 000 000 000 · Prepared by Firm consultant · For the attention of Thomas Lefèvre, deputy chief executive · Prepared on 24 September 2026

5 texts apply (GDPR, NIS2 (ReCyF), DORA, CRA, AI Act), i.e. 40 unified requirements. Reported coverage: 46%; 9 requirements with no measure at all, 17 partly covered.

## APPLICABLE TEXTS

### 5 / 5

GDPR · NIS2 (ReCyF) ·  
DORA · CRA · AI Act

## COVERAGE

### 46%

36 / 40 requirements  
assessed

## WITH NO MEASURE

### 9

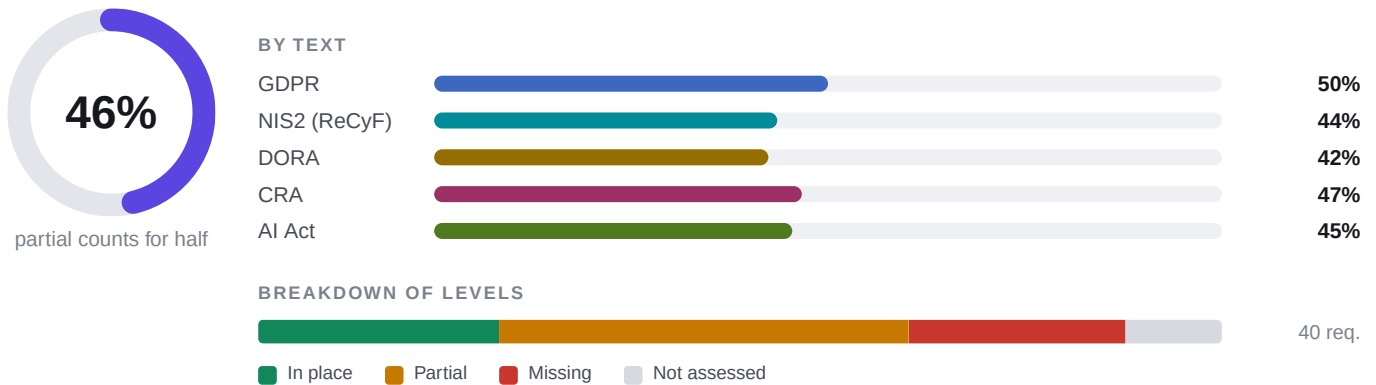
unified requirements

## MAXIMUM PENALTY

### €20M

GDPR cap

## Where we stand



## What exposes us

| TEXT         | SCOPING OUTCOME                        | COVERAGE | PENALTY CAP     |
|--------------|----------------------------------------|----------|-----------------|
| GDPR         | Controller required to designate a DPO | 50%      | €20M            |
| NIS2 (ReCyF) | Important entity                       | 44%      | €7M             |
| DORA         | Financial entity                       | 42%      | National regime |
| CRA          | Manufacturer, default product          | 47%      | €15M            |
| AI Act       | Deployer, limited risk                 | 45%      | €900k           |

## Where to start

- Accountability of the management body** GDPR + NIS2 (ReCyF) + DORA + AI Act  
Set up a single governance body (a security and compliance committee) that formally approves policies, monitors indicators and records its decisions. A single, properly drafted resolution counts as approval under each of these texts.  
Today: missing · Owner: Executive management · Effort 3/5
- Documentation and policies** GDPR + NIS2 (ReCyF) + DORA + CRA + AI Act  
Build a single documentation set, with a framework policy and topic policies, each carrying a mapping table to the articles it satisfies. This table is what turns an internal document into evidence of compliance.  
Today: missing · Owner: Compliance · Effort 3/5

3

### Notifying incidents to the authority

Build a single notification matrix (event, qualification, authority, deadline, template, owner) and rehearse it. The shortest clock drives the mobilisation of the crisis unit, even if the other deadlines are longer.

Today: missing · Owner: CISO · Effort 4/5

GDPR + NIS2 (ReCyF) + DORA + CRA + AI Act

Roadmap

|                                                                                                                                                                                                                                         |                                                                                                                                                                                                                                         |                                                                                                                                                                                                                        |                                                                                                                                                                                                                                                    |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Phase 1 · 0 to 3 months</b><br>4 requirements <ul style="list-style-type: none"><li>· Accountability of the management body</li><li>· Documentation and policies</li><li>· Notifying incidents to the authority and 1 more</li></ul> | <b>Phase 2 · 3 to 6 months</b><br>6 requirements <ul style="list-style-type: none"><li>· Third-party register and mapping</li><li>· Testing, exercises and audits</li><li>· Lex specialis: DORA prevails over NIS2 and 3 more</li></ul> | <b>Phase 3 · 6 to 12 months</b><br>8 requirements <ul style="list-style-type: none"><li>· Regulatory registers</li><li>· Dedicated function and point of contact</li><li>· Training and awareness and 5 more</li></ul> | <b>Phase 4 · Beyond 12 months</b><br>22 requirements <ul style="list-style-type: none"><li>· Identity and access management</li><li>· Security by design, development and change</li><li>· Security detection and monitoring and 19 more</li></ul> |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

Where the weaknesses are

|            |                        |     |                         |                        |      |
|------------|------------------------|-----|-------------------------|------------------------|------|
| Governance | <div><div></div></div> | 30% | Resilience              | <div><div></div></div> | 10%  |
| Risk       | <div><div></div></div> | 50% | Third parties           | <div><div></div></div> | 25%  |
| Protection | <div><div></div></div> | 75% | Data                    | <div><div></div></div> | 100% |
| Detection  | <div><div></div></div> | 67% | Artificial intelligence | <div><div></div></div> | 50%  |
| Response   | <div><div></div></div> | 33% | Documentation           | <div><div></div></div> | 17%  |

Decisions required

1.

Approve phase 1 (4 requirements, 0 to 3 months) and its budget.
2.

Assign an owner to 10 requirements with a gap and no identified owner.
3.

Have the assessment completed: 4 requirements still to assess.
4.

Clear 1 point left to check during scoping (see the appendix of the full report).
5.

Decide on 1 mandatory requirement whose matching ISO 27001 control was excluded from the initiative.
6.

Follow the adoption of the NIS2 transposition act and set the resulting compliance timetable.

|                    |                                                     |                          |                                          |
|--------------------|-----------------------------------------------------|--------------------------|------------------------------------------|
| UPCOMING DEADLINES |                                                     | SHOULD AN INCIDENT OCCUR |                                          |
| 7 October 2026     | Resilience bill debated in the National Assembly    | GDPR                     | CNIL · from 72 h                         |
| 2 December 2026    | New prohibition and end of the marking grace period | NIS2 (ReCyF)             | Reported under DORA                      |
| 31 December 2026   | Expected enactment of the resilience act            | DORA                     | ACPR · from 4 h                          |
|                    |                                                     | CRA                      | ENISA · from 24 h                        |
|                    |                                                     | AI Act                   | Market surveillance authority · from 2 d |

Committee decisions

| NO.                                       | DECISION TAKEN | OWNER | DUE DATE |
|-------------------------------------------|----------------|-------|----------|
| 1                                         |                |       |          |
| 2                                         |                |       |          |
| 3                                         |                |       |          |
| 4                                         |                |       |          |
| Committee date: _____ Presented by: _____ |                |       |          |

Prepared from the information provided and the law as of the date shown. It replaces neither advice from counsel nor the position of the competent authority. Details, legal bases and method: full scoping report.